CISE 699 — Design Review Package (Hard Stop 2)

Thesis / Research Track

Working Title:

AI-Driven Cybersecurity Risk Management: A Systematic Review of Emerging Threats, Security Controls, and Governance Challenges

Submitted by: Gaurav Sharma

Instructor: Majid Shaalan, Ph.D.

Harrisburg University of Technology — Fall 2026

Program Track: Thesis (Research) — not a technical build/artifact track

A quick note on this package before it starts. This assignment (RU-04, the Design Review Package) is written mostly for software, machine-learning, agentic-AI, and cybersecurity-build projects, where "architecture" means a system diagram and "environment" means a runtime. My project doesn't build anything, so every section below is a direct translation: the "architecture" is the structure of my conceptual framework, the "computational method" is my systematic-review method, and the "environment" is the tools and databases I use for research instead of code. I say this once here so I don't have to keep repeating it in every section.

Confirmed dates: Hard Stop 1 (Proposal Approval) was submitted September 13, 2026. Deliverable 03 (the Literature and Requirements Brief) was submitted and has already been evaluated, with individualized feedback returned before this package was written. The exact due date for this package (Hard Stop 2) is not yet confirmed on my end, so I'm treating today, September 27, 2026, as my working date and will update this if the syllabus date differs.

1. AI Usage Log and Academic Integrity

This log covers every place Claude helped this round: ideation, diagram assistance, and documentation support. There's no code-generation entry, on purpose, since this is a research-only thesis and no software gets built. Each entry below is short by design, but every one still says what Claude produced versus what I decided or checked myself, since that boundary is what my supervisor's last two rounds of feedback specifically asked to see.

Entry 1 — Translating the Assignment Itself

AI Tool: Claude (Anthropic AI assistant)
What I Used It For: Worked out which parts of the Hard Stop 2 instructions, written for software/ML/agentic-AI/cybersecurity build projects, actually apply to a literature-review thesis, and mapped each one to a research-track equivalent.
Boundary (Mine vs. Claude's): Claude proposed the mapping; I decided whether each translation actually fit my project, and rejected one suggestion (treating the diagram tool choice as "architecture" on its own) because a diagram shows architecture, it isn't the architecture.

Entry 2 — Building the Conceptual Framework Diagram

AI Tool: Claude (Anthropic AI assistant), Python (matplotlib, rendering only)
What I Used It For: Turned the old text-only arrow line into an actual box-and-arrow diagram (Section 2.2), since my supervisor's feedback asked for "a proper visual model."
Boundary (Mine vs. Claude's): Claude wrote the drawing code. I decided the eight stages, their order, their labels, and where the feedback loop points, since that's the substance of my framework, not a drawing choice.

Entry 3 — Building the Traceability Matrix

AI Tool: Claude (Anthropic AI assistant)
What I Used It For: Built the requirement-to-design-to-evidence table (Section 5.2) my supervisor asked for twice, matching each of the eleven requirements to a framework stage and an evaluation check.
Boundary (Mine vs. Claude's): Claude drafted the first pass. I corrected two rows myself (FR5 and NFR4), since both are document-wide readability requirements, not single-stage ones, and the first draft forced them into one stage each.

Entry 4 — Setting Evaluation Thresholds

AI Tool: Claude (Anthropic AI assistant)
What I Used It For: Turned my existing quality checks (PRISMA, AMSTAR 2, framework mapping, screening volume) into measurable thresholds with explicit failure conditions, avoiding the vague language the assignment warns against.
Boundary (Mine vs. Claude's): Claude proposed wording and numbers. I set the actual thresholds from what I already knew (the 40-to-80-source range, PRISMA's 27 items, AMSTAR 2's four levels), and rejected one suggested statistic I hadn't verified anywhere else in this project.

Entry 5 — Researching Two New NIST Sources

AI Tool: Claude (Anthropic AI assistant), web search
What I Used It For: Checked NIST's COSAiS project and NIST SP 1353, both flagged in my supervisor's Deliverable 03 feedback, before deciding whether to cite either one.
Boundary (Mine vs. Claude's): Claude found and summarized both from csrc.nist.gov. I decided how to use them, flagging both as still-evolving guidance rather than settled standards, per the currency rule (NFR2) already in place.

Entry 6 — Building the Method Comparison Table

AI Tool: Claude (Anthropic AI assistant)

What I Used It For: Built the table in Section 2.5 comparing PRISMA, Kitchenham & Charters, Tranfield et al., and NIST's own workshop process, since my supervisor's feedback specifically asked for a clearer comparative-method table.
Boundary (Mine vs. Claude's): Claude drafted the comparison language. I decided which method got adopted and why, and specifically decided NIST's process should be tracked as a comparison point rather than an adopted method, since it isn't a reproducible literature-review method.

Entry 7 — Drafting the Risk Register and Tradeoffs Section

AI Tool: Claude (Anthropic AI assistant)
What I Used It For: Drafted the risk register (Section 6) and the new tradeoffs/edge-cases section (2.7), covering what could go wrong with this design and the two deliberate tradeoffs behind it.
Boundary (Mine vs. Claude's): Claude proposed wording. I decided which risks were real and their status (mitigated, accepted, or still open), especially the single-reviewer screening bias, which I marked as only partially mitigated since it still needs my supervisor's sign-off.

Entry 8 — Structuring the Full Document

AI Tool: Claude (Anthropic AI assistant)
What I Used It For: Put Entries 1–7's material into one document following the RU-04 rubric's five categories, in the same plain, no-color style as the rest of this series.
Boundary (Mine vs. Claude's): Claude drafted the remaining connective prose (Sections 3 and 7). I checked every paragraph against my own understanding of the project and corrected wording that sounded more confident than I actually am about anything still unfinished.

Note on the twenty references carried over from Assignment 3: those were sourced and verified in Assignment 1, Hard Stop 1, and Assignment 3, with the trail already on record in each of those AI Usage Logs, so I only re-verified the two new sources added this round (Entry 5).

Nothing in this log reflects an AI judgment about whether my project is good or my framework is correct. In every entry, Claude produced a first draft and I either confirmed it against something already established in this project or changed it because it didn't hold up. That judgment is mine, and ultimately my supervisor's.

2. Conceptual Architecture and Review Method

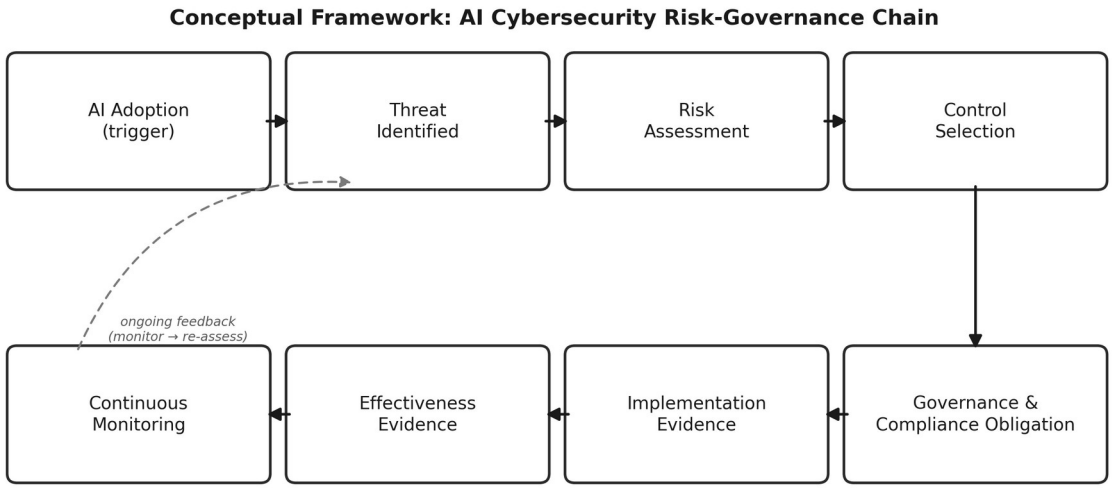
This section covers the first RU-04 rubric category, Architecture and Method Selection. Since nothing here gets built, “architecture” means the structure of my conceptual framework, and “computational method” means my systematic-review method. Both get the same level of detail a software architecture and algorithm description would get, just translated.

2.1 From Approved Requirements to a Formal Design

Assignment 3 set six functional requirements and five non-functional requirements for this project's conceptual framework, and those are still the requirements this design has to satisfy, nothing here replaces them. What this section adds is the formal structure connecting those requirements together: which “components” (framework stages) exist, what each one is responsible for, what feeds into it, what comes out of it, and what order they run in. That structure is the diagram and table below, and the full requirement-to-design mapping is in Section 5.2.

2.2 The Conceptual Framework Diagram

My supervisor's Deliverable 03 feedback asked for the conceptual chain to become “a proper visual model” instead of the plain arrow-text line used in Hard Stop 1 and Assignment 3. Below is an actual box-and-arrow diagram, built the same way a software team would draw a pipeline or C4 diagram, showing the eight stages of the framework and the one feedback loop running through it.



The chain reflects my supervisor's own updated framing from the Deliverable 03 feedback: threat, to risk assessment, to control selection, to governance obligation, to implementation evidence, to effectiveness evidence, to continuing monitoring. I added “AI Adoption” as the

entry trigger at the front, since a chain that starts at “threat” has no visible starting condition, and the practical trigger for all of this is an organization adopting AI somewhere that touches its cybersecurity posture.

2.3 Component Responsibilities

The table below answers the same four questions a software architecture diagram is supposed to answer for each component: what it's responsible for, what it depends on, what goes in, and what comes out.

Stage	Responsibility	Depends On (Input)	Produces (Output)
AI Adoption (trigger)	Marks the point where an organization starts using AI somewhere that touches its cybersecurity posture. Not a control itself, just the entry condition.	Nothing upstream; this is the starting point.	A flagged AI-cybersecurity touchpoint worth evaluating.
Threat Identified	Names the specific AI-related threat, described at a categorical level (MITRE ATLAS-style) and sorted into one of the seven risk categories from Assignment 1.	The AI-adoption trigger, plus the threat literature (Kaur et al., 2023; MITRE ATLAS, n.d.).	A classified threat, tagged to one of the seven categories.
Risk Assessment	Judges how serious the classified threat actually is in context, so effort isn't spent on low-priority items.	The classified threat from the previous stage.	A prioritized risk, ready to be matched to a control.
Control Selection	Matches the prioritized risk to a candidate security control drawn from the reviewed literature, including NIST's emerging control-overlay work where relevant.	The prioritized risk, plus the control literature (Albulayhi & Alkhalifah, 2026; NIST COSAiS project, 2025).	A candidate control, not yet tied to a governance rule.
Governance & Compliance Obligation	Ties the selected control to a specific function or clause inside one of the three governance frameworks (NIST AI RMF, ISO/IEC 42001, NIST CSF 2.0).	The candidate control from the previous stage.	A control mapped to a named governance requirement, or explicitly flagged unresolved per FR6 if no clean mapping exists.
Implementation Evidence	Records that the mapped control was actually put in place, not just selected on paper.	The governance-mapped control.	A documented record that the control exists and is operating.
Effectiveness Evidence	Checks whether the implemented control is actually reducing the risk it was chosen for, not just present.	The implementation record.	A judgment, backed by evidence, on whether the control is working.
Continuous Monitoring	Watches for new threats, framework changes, or control drift over time, and feeds anything new back into Threat Identified.	The effectiveness evidence, plus ongoing awareness of framework and regulatory changes.	Either confirmation nothing has changed, or a new item fed back to the top of the chain.

2.4 Review Method (In Enough Detail to Reproduce)

The assignment asks for the computational method to be documented well enough that another technically trained reader could reproduce it. My method has five steps. First, search: run the search strings already logged in Assignment 1 and Hard Stop 1 across the seven sources in Section 3.4, using Litmaps alongside Zotero to catch related work the keyword searches miss. Second, screen: apply the include/exclude criteria from Hard Stop 1 to every result, logging a reason for every decision, targeting the 40-to-80-source range already committed to. Third, code: sort every included source into the seven risk categories from Assignment 1. Fourth, synthesize: pull the coded sources together using narrative synthesis (Popay et al., 2006), organized by the themes in Assignment 3, Section 2. Fifth, validate: map the resulting framework against the three governance frameworks function by function, and score the whole review using AMSTAR 2 and the PRISMA 2020 checklist. Every one of these five steps produces a document or a log entry, so another researcher could follow the same steps and check my work against those records.

2.5 Method Comparison

My supervisor's Deliverable 03 feedback specifically asked for a clearer comparative-method table. The table below compares the four methods that shaped this review, and says plainly why each one was or wasn't adopted.

Method	Origin	Strength	Why Adopted or Not
PRISMA 2020 (Page et al., 2021)	Clinical and health-sciences systematic reviews	Most widely recognized reporting standard; 27-item checklist gives a built-in audit trail	Adopted as the core reporting structure for this whole review
Kitchenham & Charters (2007)	Software-engineering systematic reviews	Search-string and inclusion-criteria guidance closer to a technical field than PRISMA's mostly clinical examples	Adopted as a supporting reference, mainly for search-string design
Tranfield, Denyer & Smart (2003)	Management-research systematic reviews	Makes the case that systematic review methods generalize well to applied, practice-relevant fields outside medicine	Adopted as the justification for using a clinical-review-style method on a governance topic
NIST's own Cyber AI Profile process (workshops and public comment)	Government standards development (NIST IR 8578, 8596, 8607)	Draws on live, wide-ranging practitioner input in real time	Not adopted as a method, since it isn't a literature review and isn't reproducible the way an academic method needs to be; tracked instead as a comparison point in Section 4.4

2.6 Build Order (Sequence and Dependencies)

Four phases across fourteen weeks; each depends on the one before it finishing, and the pilot in weeks 9–10 is the one early-prototyping step in the plan.

Weeks	Task	Depends On	Testable / Blocks Next Phase
1–5 (in progress)	Search and setup, then confirm the exact research gap against Albulayhi & Alkhalifah (2026) and Mokgathi & Ogundele (2026).	Nothing upstream.	Gap statement reviewable on its own. Blocks the coding scheme.
6–8	Full screening and coding into the seven risk categories.	Confirmed gap statement.	Screening-reliability spot-check (4.2). Blocks the framework build.
9–10	Build the eight-stage framework; pilot the framework-validation mapping on 5–8 sources before scaling up.	Completed coding.	The early-prototyping step; reviewed with my supervisor before full validation.
11–14	Full framework validation against the three governance frameworks; AMSTAR 2 and PRISMA checklists finalized; conclusion written.	A successful pilot.	Framework-mapping completeness check (4.2). Last phase, blocks nothing further.

2.7 Tradeoffs and Edge Cases

Two tradeoffs were deliberate. First, PRISMA over a faster narrative-only review: PRISMA costs more time (the full 27-item checklist, a logged reason for every screening decision) but buys reproducibility, which a narrative review can't offer and which NFR1 specifically requires. Second, eight stages instead of a simpler six: splitting implementation evidence from effectiveness evidence adds a stage to track, but a control that's merely selected on paper is not the same claim as a control that's actually working, and collapsing the two would hide exactly the gap this thesis is built to expose.

Two edge cases the design has to handle, not just the clean case. If a source doesn't fit neatly into one of the seven risk categories, it gets logged under its closest primary category with a note flagging the overlap, rather than forced into a false single bucket, the same principle FR6 already applies to governance mappings. If a single control turns out to satisfy several governance requirements at once, or a requirement needs several controls, that many-to-many relationship gets recorded as-is in the framework-mapping table (Section 4.5) instead of being simplified into a one-to-one line that would misrepresent it.

3. Research Environment, Tools, and Data Planning

This section covers the second RU-04 rubric category, Environment, Toolchain, Data, and API Planning. There's no runtime, no server, and no code here, so every part of this section is a direct translation of what a software project would call its development environment.

3.1 Confirmed Research Environment

My working setup is a personal computer running Zotero desktop (version 7.x) as my reference manager, Litmaps as a web-based citation-mapping and discovery tool, and Microsoft Word for writing, all connected to university-licensed database access through institutional single sign-on. There's no hardware requirement beyond a normal laptop, no GPU, and no server, since nothing here runs a model or processes data at scale.

3.2 Toolchain

Tool Dimension	Recommended Baseline	Options Considered	Evidence I'll Submit
Machine (research setup)	Personal computer, Zotero desktop 7.x, Microsoft Word, institutional single sign-on for database access.	Litmaps added this term alongside Zotero, for citation mapping and monitoring.	Screenshot or export confirming Zotero library size and Litmaps project setup.
Design/Diagramming	A rendered box-and-arrow conceptual framework diagram (Section 2.2).	UML/C4 diagrams considered and rejected, software-specific; a plain arrow-text line was used earlier and judged not detailed enough by my supervisor.	The rendered diagram plus the Component Responsibilities table (Section 2.3).
Computational/ Review Method	PRISMA 2020-based systematic review, scored with AMSTAR 2, validated against three governance frameworks.	A purely narrative, non-systematic review was considered and rejected as not reproducible enough; a meta-analysis isn't applicable since there are no numerical effect sizes to pool.	Completed PRISMA checklist, AMSTAR 2 worksheet, framework-mapping table.
Database/Repository Access	Confirmed institutional access to IEEE Xplore, ACM Digital Library, Scopus, and Web of Science, plus free access to NIST, ENISA, and EUR-Lex.	Google Scholar kept as the fallback when licensed access fails.	Access-confirmation table (Section 3.4).

3.3 Literature-Corpus (“Data”) Planning

The assignment asks for data-validation steps, a train/test/validation-style split, and bias or error checks where they apply. There's no dataset in the usual sense, the literature itself is the corpus, but the same discipline applies. Before full screening starts, I'll pilot the inclusion and exclusion criteria against a small batch of sources I already know are relevant (the equivalent of a validation split), to make

sure the criteria actually work before applying them at scale. The known bias and error risks are the same ones disclosed in Assignment 3: database coverage skews toward technical and engineering framing, non-English governance literature is largely inaccessible to me, and with only one reviewer, screening consistency depends on the spot-check described in Section 4.2 rather than a second independent coder.

3.4 Database and Repository Access ("API" Equivalent)

Where a software project would confirm its API access, mine is confirmed access to seven literature sources.

Source	Access Status	Access Method	Fallback If Unavailable
IEEE Xplore	University-licensed, confirmed	Institutional single sign-on via library proxy	Google Scholar or an author-archived copy
ACM Digital Library	University-licensed, confirmed	Institutional single sign-on	Google Scholar
Scopus / Web of Science	University-licensed, confirmed	Institutional single sign-on	Google Scholar
Google Scholar	Freely accessible	None required	Already the fallback for the sources above
NIST publications	Freely accessible	None required	Not applicable
ENISA publications	Freely accessible	None required	Not applicable
EUR-Lex / EU Official Journal	Freely accessible	None required	Not applicable

3.5 Reproducibility Check

The assignment asks four specific questions, so I'll answer each one directly. Can another person recreate my environment? Yes: Zotero is free and cross-platform, Litmaps is web-based, and the seven data sources in Section 3.4 are the same ones listed for the whole program. Have I pinned important versions? Yes for Zotero (version 7.x, since citation-file formats can shift between versions); Litmaps is web-based, so there's no version to pin, but I've noted when I set up my project inside it. Are external dependencies documented? Yes, all seven sources are listed with access method and fallback in Section 3.4. Are there services, credentials, ports, GPUs, memory, or operating-system assumptions? No GPUs, no ports, and nothing operating-system-specific, since nothing here runs code. The only credential involved is my own university single sign-on login, which is already required and already working.

4. Evaluation and Validation Plan

This section covers the third RU-04 rubric category, Testing and Evaluation Design. The assignment is explicit that vague language like "the review should be good" isn't acceptable, every check below has a number or a clear yes/no condition attached.

4.1 What Is Being Evaluated

Two separate things get evaluated here: the review process itself (was it thorough and reproducible?) and the conceptual framework it produces (does it actually connect threats to controls to governance in a defensible way?). The checks below cover both.

4.2 Checks, Metrics, and Acceptance Thresholds

Check	Metric	Acceptance Threshold	What Counts as Failure
PRISMA 2020 completeness	Percentage of the 27 checklist items satisfied	100% (27 of 27) at final submission	Any item left unaddressed at submission, with no documented reason
AMSTAR 2 self-appraisal	Overall confidence rating (High, Moderate, Low, or Critically Low) plus count of weak spots	Moderate or higher, no more than two non-critical weaknesses, zero critical-domain failures	A Low or Critically Low overall rating, or any critical-domain failure
Screening consistency spot-check	Percentage agreement between my original screening decisions and a second-pass re-check on a random sample	At least 90% agreement on a 10% random resample; disagreements resolved and logged	Agreement below 90% with no documented resolution
Framework-mapping completeness	Percentage of relevant functions/clauses across the three governance frameworks that receive at least one mapped control, or an explicit unresolved flag	At least 90% of relevant functions addressed (mapped or explicitly flagged unresolved per FR6)	A function left blank with no mapping and no unresolved flag
Source-coverage benchmark	Number of full-text screened sources; percentage of include/exclude decisions logged with a reason	40 to 80 sources screened; 100% of decisions logged with a reason	Fewer than 40 sources without justification, or any undocumented decision
Currency check	Percentage of fast-moving governance developments (Cyber AI Profile, COSAiS, EU AI Act phase-in) flagged with a publication date and draft/applicability status	100% flagged, none cited as settled if still in draft or phased rollout	Any moving-target reference cited as if it were finished and fully in force

4.3 What Counts as Failure, Stated Plainly

Beyond the table above: if my final review can't produce a completed PRISMA checklist, an AMSTAR 2 rating of Moderate or better, and a framework-mapping table with at least 90 percent of relevant functions addressed, the review has not met its own success criteria, regardless of how polished the writing is. That's the standard I'm holding myself to, not just “did I write enough pages.”

4.4 Baseline and Comparison Logic

My comparison isn't against a single baseline number, since there's no prior version of this exact framework to compare against. Instead, the comparison is against the two closest existing reviews: Albulayhi and Alkhalifah (2026) and Mokgathi and Ogundele (2026). Neither one builds a traceable threat-to-control-to-governance chain, that's the whole gap this thesis targets, so the bar I'm measuring against is presence versus absence: does my framework achieve documented, function-level traceability where the two closest existing reviews do not? NIST's own Cyber AI Profile effort is a second comparison point, not a baseline to beat but a parallel effort using a different method (workshops instead of literature review) toward a similar goal, tracked separately per the currency rule in Section 4.2.

4.5 Evidence Collection Plan

- Screening tracker: every source with its title, year, category, include/exclude decision, and reason (already the project's core data schema, from Assignment 3, Section 3.4).
- Completed PRISMA 2020 checklist, kept as a living document until final submission.
- Completed AMSTAR 2 worksheet, filled out once screening and coding are finished.
- Framework-mapping table, produced during the framework-validation pilot and then the full validation (Section 2.6, weeks 9–12).
- Resampling log for the screening-consistency spot-check, dated and kept alongside the screening tracker.

Each check above ties back to one or more rows in the Section 5.2 traceability matrix and has its own stated failure condition, so success and failure are both defined now, before screening and validation accelerate, not decided after the fact.

5. Traceability and Design Rationale

This section covers the fourth RU-04 rubric category, Design Rationale, Traceability, and Communication. My supervisor asked for a true literature-to-requirement traceability matrix twice now, once in general Hard Stop 2 guidance and once by name in the Deliverable 03 feedback, so this is the most important table in this package.

5.1 Why This Matters Here

The assignment's own test is simple: point to any one requirement, and I should be able to show exactly where it's addressed in the design and how it will eventually be tested. Before this package, my requirements had “Traced to:” phrases pointing back to earlier documents, which is a weaker, one-directional version of real traceability. The table below closes that gap by connecting every requirement to a specific framework stage and a specific evaluation check, so the connection runs all the way through, not just backward to where the requirement came from.

5.2 Requirement-to-Design-to-Evidence Traceability Matrix

Requirement	Design Element (Framework Stage)	Test / Evidence
FR1	Threat Identified stage; the seven-category taxonomy from Assignment 1.	Screening-consistency spot-check (Section 4.2).
FR2	Control Selection stage.	Framework-mapping completeness check (Section 4.2).
FR3	Governance & Compliance Obligation stage.	Framework-mapping completeness check (Section 4.2).
FR4	Threat Identified stage (dual-use, categorical-only description).	Manual read-through with my supervisor before submission; no automated check applies to a writing-style requirement.
FR5	Cuts across every stage; this is a document-wide readability requirement, not a single-stage one.	Plain-language self-check plus supervisor review (shared with NFR4).
FR6	Governance & Compliance Obligation stage.	Framework-mapping completeness check; an explicitly flagged unresolved mapping counts as a pass, not a failure.
NFR1 (Reproducibility)	Review Method (Section 2.4).	PRISMA 2020 completeness check (Section 4.2).
NFR2 (Currency)	Governance & Compliance Obligation stage; References section.	Currency check (Section 4.2).
NFR3 (Auditability)	Review Method (Section 2.4).	AMSTAR 2 self-appraisal (Section 4.2).
NFR4 (Plain language)	Cuts across every stage, same as FR5.	Plain-language self-check plus supervisor review.
NFR5 (Format compliance)	Document formatting overall.	Visual/PDF spot-check before every submission, an established habit in this series.

5.3 Design Rationale, In Short

Every major decision in this package traces back to one of two things: a gap that Albulayhi and Alkhalifah (2026) documented at scale, or my supervisor's own framing of what this thesis is actually trying to do. The eight-stage chain exists because a shorter version (the six-stage line used in Hard Stop 1 and Assignment 3) collapsed “implementation” and “effectiveness” into one “monitoring” step, which my

supervisor's Deliverable 03 feedback pulled apart into two separate, more honest questions: was the control actually put in place, and is it actually working? Those are different questions with different evidence, so they needed to be different stages. The pilot step in Section 2.6 exists because the framework-validation mapping is the single highest-risk part of this whole design (Section 6), and testing it small before testing it fully is the only honest way to de-risk it.

6. Risks, Missing Dependencies, and Build-Order Confirmation

This section covers the assignment's explicit request to review design risks, missing dependencies, and evaluation gaps with my supervisor, and to be able to give a week-by-week build order without hesitation.

6.1 Risk Register

Risk	Why It Matters	De-risking Action	Status
Loss of access to a licensed database mid-review	Could stall screening for weeks if it happens without a plan	Fallback to Google Scholar or author-archived copies, already defined in Section 3.4	Mitigated
Single-reviewer screening bias (no second coder)	Screening decisions could be inconsistent with no one else checking them	Supervisor spot-check on a 10% random resample, target at least 90% agreement (Section 4.2)	Partially mitigated; needs my supervisor's confirmation this arrangement is acceptable
Governance references still in draft or moving (Cyber AI Profile, COSAiS, EU AI Act phase-in)	Citing them as settled would misrepresent their actual status	Currency-flagging rule (NFR2) already applied consistently since Assignment 3	Mitigated
English-language and database-coverage bias	Could miss relevant non-English governance literature	Disclosed explicitly as a known limitation rather than hidden (Section 3.3)	Accepted risk, disclosed, not eliminated
Framework mappings may not be clean one-to-one, per my supervisor's own hidden-assumption note	One control could satisfy several governance requirements or vice versa	FR6 requires unresolved or many-to-many mappings to be flagged rather than forced into a false one-to-one shape	Mitigated by design; edge cases still need supervisor review

6.2 Highest-Risk Dependency and De-risking Plan

The highest-risk part of this whole design is the framework-validation mapping step, Control Selection into Governance & Compliance Obligation. It's the one stage that hasn't been tested yet, and if it doesn't work, the entire traceability claim this thesis is built around falls apart. My de-risking plan is already in the build order (Section 2.6, weeks 9–10): pilot the mapping approach on a small set of five to eight already-screened sources first, review that pilot with my supervisor, and only then scale up to the full validation in weeks 11 and 12. If the pilot shows the mapping doesn't work cleanly, I'll find that out on eight sources instead of eighty.

6.3 Build-Order Self-Check

Could I give my supervisor a week-by-week build order tomorrow? Yes, it's the table in Section 2.6: search and setup first, then the gap statement, then screening and coding, then the framework build with its pilot test, then full validation, then the closing checklists. Each phase depends on the one before it finishing, and the pilot in weeks 9 and 10 is the one piece of early prototyping in the whole plan, exactly the kind of thing this assignment asks students to identify.

7. Answers to the Seven Pre-Submission Questions

The assignment lists seven questions a student should be able to answer without hesitation before submitting, so here they are in plain terms, each pointing back to where the full answer lives. The architecture is the eight-stage conceptual chain in Section 2.2, described stage by stage in Section 2.3, and I chose it because it's the structure my supervisor's own Deliverable 03 feedback described, one that directly closes the gap Albulayhi and Alkhalifah (2026) documented at scale (Sections 2.1 and 5.3). The eight stages are the major components, and the requirement-to-stage links in Section 5.2 are the interfaces connecting them. The environment and dependencies are Zotero, Litmaps, Microsoft Word, and confirmed access to seven literature sources, all covered in Section 3. The exact computational method is a PRISMA 2020-based systematic review with narrative synthesis, scored using AMSTAR 2 (Section 2.4). Success gets tested against the six checks in Section 4.2, each with a specific number or an explicit pass-or-fail condition, and the biggest risks, along with how I plan to address them early, are laid out in the risk register in Section 6, especially the framework-validation pilot planned for weeks 9 and 10.

8. References

Twenty-two sources now: the twenty already verified across Assignments 1 and 3 and Hard Stop 1, plus two new additions this round to cover the NIST developments my supervisor's Deliverable 03 feedback specifically pointed to. All APA 7th edition.

Kaur, R., Gabrijelčič, D., & Klobučar, T. (2023). Artificial intelligence for cybersecurity: Literature review and future research directions. *Information Fusion*, *97*, Article 101804. https://doi.org/10.1016/j.inffus.2023.101804

Anchors the problem-definition theme and the Threat Identified stage.

Albulayhi, O., & Alkhalifah, A. (2026). AI governance risk tiering for sustainable digital infrastructure: A systematic review of cybersecurity frameworks. *Sustainability*, *18*(6), Article 2986. https://doi.org/10.3390/su18062986

The strongest evidence that the traceability gap this thesis targets is real; also the comparison point used in Section 4.4.

Mokgathi, M., & Ogundele, O. S. (2026). Information technology (IT) risk governance and cybersecurity threats: A systematic literature review. In *Embracing technological agility in accounting and business* (Vol. 2). Springer.

The second comparison point used in Section 4.4; treats AI as one item among many rather than its own connective problem.

National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)* (NIST AI 100-1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.AI.100-1

One of the three frameworks the Governance & Compliance Obligation stage validates against.

National Institute of Standards and Technology. (2025). *Cybersecurity framework profile for artificial intelligence (Cyber AI profile)* (NIST IR 8596, Initial Preliminary Draft). U.S. Department of Commerce.

The institutional effort closest to this thesis's own goal; released as a preliminary draft in December 2025.

National Institute of Standards and Technology. (2026). *Workshop summary report for "Cyber AI Profile" hybrid workshop #2* (NIST IR 8607). U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/ir/2026/NIST.IR.8607.pdf

Shows the next iteration of NIST's profile taking shape around the same governance-and-controls territory this thesis maps through literature review instead.

National Institute of Standards and Technology. (2025). *SP 800-53 control overlays for securing AI systems (COSAiS)* [Concept paper]. U.S. Department of Commerce. https://csrc.nist.gov/projects/cosais

New to this package. My supervisor flagged this as especially relevant to my Control Selection stage; still an early-stage, evolving project as of this writing, cited and used narrowly for that reason.

National Institute of Standards and Technology. (2026). *NIST Cybersecurity Framework 2.0: Quick-start guide for using artificial intelligence (AI) for CSF analysis and reporting* (NIST SP 1353, Initial Public Draft). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.1353.ipd

New to this package. Supports the evidence-to-outcome mapping approach used in Section 4; cited as a draft, not a finished guide.

Zeijlemaker, S., Lemiesa, Y. K., Schröer, S. L., Abhishta, A., & Siegel, M. (2025). How does AI transform cyber risk management? *Systems*, *13*(10), Article 835. https://doi.org/10.3390/systems13100835

Grounds the abstract governance discussion in a real case, the Colonial Pipeline attack.

Page, M. J., McKenzie, J. E., Bossuyt, P. M., Boutron, I., Hoffmann, T. C., Mulrow, C. D., Shamseer, L., Tetzlaff, J. M., Akl, E. A., Brennan, S. E., Chou, R., Glanville, J., Grimshaw, J. M., Hróbjartsson, A., Lalu, M. M., Li, T., Loder, E. W., Mayo-Wilson, E., McDonald, S., … Moher, D. (2021). The PRISMA 2020 statement: An updated guideline for reporting systematic reviews. *BMJ*, *372*, Article n71. https://doi.org/10.1136/bmj.n71

The 27-item reporting checklist behind the PRISMA completeness check in Section 4.2.

Kitchenham, B., & Charters, S. (2007). *Guidelines for performing systematic literature reviews in software engineering* (EBSE Technical Report EBSE-2007-01). Keele University and University of Durham.

Supports the search-string and inclusion-criteria design referenced in Section 2.4 and Section 2.5.

Tranfield, D., Denyer, D., & Smart, P. (2003). Towards a methodology for developing evidence-informed management knowledge by means of systematic review. *British Journal of Management*, *14*(3), 207–222. https://doi.org/10.1111/1467-8551.00375

Justifies using a clinical-review-style method on a governance topic; discussed in Section 2.5.

Popay, J., Roberts, H., Sowden, A., Petticrew, M., Arai, L., Rodgers, M., Britten, N., Roen, K., & Duffy, S. (2006). *Guidance on the conduct of narrative synthesis in systematic reviews: A product from the ESRC Methods Programme* (Version 1). Lancaster University.

Supports the narrative-synthesis step described in Section 2.4.

International Organization for Standardization, International Electrotechnical Commission, & Institute of Electrical and Electronics Engineers. (2018). *Systems and software engineering — Life cycle processes — Requirements engineering* (ISO/IEC/IEEE 29148:2018). https://www.iso.org/standard/72089.html

The formal standard behind the requirement vocabulary this package's traceability matrix builds on.

International Organization for Standardization. (2023). *Information technology — Artificial intelligence — Management system* (ISO/IEC 42001:2023). https://www.iso.org/standard/42001.html

One of the three frameworks the Governance & Compliance Obligation stage validates against.

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). U.S. Department of Commerce. https://doi.org/10.6028/NIST.CSWP.29

The third validation benchmark; its Govern function maps closely to this thesis's governance layer.

European Parliament and Council of the European Union. (2024). *Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. Official Journal of the European Union. https://eur-lex.europa.eu/eli/reg/2024/1689/oj

The one binding hard-law source in this list; enforcement powers and general-purpose-AI obligations became applicable August 2, 2026, with other provisions phased in later.

MITRE Corporation. (n.d.). *MITRE ATLAS: Adversarial threat landscape for artificial-intelligence systems*. Retrieved September 2026, from https://atlas.mitre.org

The taxonomy behind the categorical, non-operational threat descriptions required by FR4.

Committee on Publication Ethics. (2024). *Authorship and AI tools* [Position statement]. https://publicationethics.org/guidance/cope-position/authorship-and-ai-tools

The standard behind how AI assistance is disclosed throughout this project's AI Usage Logs.

International Committee of Medical Journal Editors. (n.d.). *Defining the role of authors and contributors*. Retrieved September 2026, from https://www.icmje.org/recommendations/browse/roles-and-responsibilities/defining-the-role-of-authors-and-contributors.html

Supports the accountability point behind every “Boundary of Contribution” line in Section 1.

Association for Computing Machinery. (2018). *ACM code of ethics and professional conduct*. https://www.acm.org/code-of-ethics

The general professional-ethics backdrop for this project, most relevant to the dual-use risk behind FR4.

Shea, B. J., Reeves, B. C., Wells, G., Thuku, M., Hamel, C., Moran, J., Moher, D., Tugwell, P., Welch, V., Kristjansson, E., & Henry, D. A. (2017). AMSTAR 2: A critical appraisal tool for systematic reviews that include randomised or non-randomised studies of healthcare interventions, or both. *BMJ*, *358*, Article j4008. https://doi.org/10.1136/bmj.j4008

Produces the four-level confidence rating behind the AMSTAR 2 self-appraisal check in Section 4.2.

9. Next Step: Supervisor Review

The assignment asks for this package to be reviewed with my supervisor before implementation, meaning before the full screening and framework-validation work accelerates. Two things specifically need a decision: whether the single-reviewer screening spot-check in Section 4.2 is an acceptable substitute for a second independent coder, and whether the eight-stage split of “implementation evidence” and “effectiveness evidence” matches what my supervisor meant in the Deliverable 03 feedback, or whether it should be drawn differently. Everything else in this package, I'm treating as ready to act on.